

SBMS Implementation Audit Roadmap

Project analysis, implementation priorities, role mapping, and test roadmap

Date: 2026-05-15

Workspace: `I:\SBMS Copy`

Purpose

This document summarizes what is already implemented in the SBMS project, what is partially implemented, what is missing, and the recommended step-by-step execution plan for the next delivery phases.

The current focus areas requested are:

1. WebSocket implementation
2. Java Mail based OTP email and automated notification email
3. Monthly closing, profit/loss, KPI, loan tracking, loan recovery report, growth reporting
4. Role-wise process validation and end-to-end implementation audit
5. RBAC refinement, including missing roles and unclear create/open ownership

Executive Summary

What appears already in good shape

- Role and permission based access control foundation exists in both backend and frontend.
- OTP verification flow is already implemented in the backend with email and SMS delivery abstraction.
- Login OTP and step-up verification flow already exist.
- Workflow history, pending approval queue, and dashboard modules already exist.
- Reporting, statement preview, print, export, PDF, and Excel generation foundation is already present.
- Financing, contracts, KYC, statements, profit, workflow, security, and zakat modules already have significant functional coverage.

What appears partial or missing

- No clear WebSocket implementation was found in the backend scan.
- Java Mail configuration exists, but production readiness depends on real SMTP configuration and live end-to-end verification.
- Monthly closing as a formal business process is not clearly implemented.
- Profit and financing analytics exist, but a dedicated profit-loss statement engine was not clearly found.
- Loan tracking is partially covered through financing application, disbursement, repayment, and portfolio reporting.
- Loan recovery reporting is not clearly present as a dedicated feature.
- Growth reporting exists only partially through dashboards and operational reports.
- Several process ownership points are still ambiguous across roles.

Audit Findings By Area

1. WebSocket

Current finding

The backend scan did not show a clear WebSocket implementation. No solid evidence was found for:

- `@EnableWebSocketMessageBroker``
- `SimpMessagingTemplate``
- `@MessageMapping``
- `@SendTo``
- dedicated WebSocket config class

Conclusion

WebSocket appears to be not implemented yet, or not implemented in a production-ready way.

Recommendation

Implement Spring Boot STOMP WebSocket with event channels for:

- real-time notification delivery
- workflow approval updates
- OTP status feedback where appropriate
- report/export completion status
- investigation/security alerts
- branch or teller operational alerts

Recommended implementation order

1. Add backend WebSocket configuration
2. Add topic structure and secured destinations
3. Publish notification events from workflow, verification, reports, security modules
4. Add Angular WebSocket service
5. Add role-aware real-time notification center in UI
6. Add connection/auth/session tests

2. Java Mail OTP And Automated Mail

Current finding

The project already has real email OTP building blocks:

- `spring.mail.*`` configuration exists in backend `application.properties``
- `JavaMailSender`` is used in `VerificationDeliveryService``
- OTP email and SMS abstraction is implemented
- simulator fallback exists
- verification templates and provider test flow exist
- login OTP and password reset OTP flow exist

Conclusion

This area is partially implemented and structurally good, but live production-readiness depends on configuration and testing.

What still needs to be completed

1. Real SMTP credential setup through environment variables
2. Sender identity verification and domain configuration
3. HTML email templates for:
 - login OTP
 - verification OTP
 - password reset
 - workflow approval request
 - workflow approved / rejected notices
 - financing document or contract notices
 - statement/report completion notices
4. Retry/failure strategy and delivery monitoring
5. Mail audit logging
6. Role-wise automated mail triggers

Recommended automated mail events

- Customer onboarding submitted
- KYC moved to review
- KYC approved / returned / rejected
- Account opening approved / rejected
- Financing file submitted
- Financing approved / correction requested / disbursed
- Contract generated / ready for signing
- Statement/report export ready
- Password reset initiated
- Security investigation escalated

3. Monthly Closing, Profit/Loss, KPI, Loan Tracking, Loan Recovery, G

Current finding

Found

- Branch EOD and vault closing related components exist
- Profit ratio, schedule, posting, and dashboard exist
- Financing application, review, disbursement, repayment collection, and financing portfolio reporting exist
- PAR report and financing portfolio report exist
- Dashboard KPI cards exist in multiple modules
- Calculation engine exists

Not clearly found as dedicated modules

- full monthly closing workflow
- formal profit and loss statement generation
- dedicated loan recovery report
- growth analysis report pack
- management closing checklist with sign-off

Conclusion

This area is only partially implemented. Core data points exist, but formal business reporting/process orchestration is incomplete.

Recommended delivery plan

Phase A: Monthly Closing

Implement:

- monthly closing header and period control
- close prerequisites checklist
- branch close status
- profit posting completion check
- exception summary
- sign-off by operations and branch manager
- closing freeze and reopen control

Phase B: Profit And Loss

Implement:

- income and expense mapping source tables
- profit/loss aggregation service
- monthly and yearly P&L report
- branch-wise and consolidated view
- export PDF/Excel

Phase C: Loan / Financing Tracking

Implement or validate:

- application submitted
- under review
- shariah review
- approved
- disbursed
- repayment ongoing
- overdue
- recovered / closed

Phase D: Loan Recovery Report

Implement:

- overdue bucket report
- branch-wise overdue list
- product-wise overdue exposure
- recovery officer work queue
- promised recovery tracking
- recovered vs pending analysis

Phase E: Growth And KPI

Implement:

- deposit growth trend
- customer acquisition growth
- financing growth trend

- branch performance growth
- recovery efficiency KPI
- statement/report usage KPI

4. Role-Wise Process Audit

Current finding

Frontend menu and permission routing already define a strong role skeleton for:

- CUSTOMER
- TELLER
- OPERATIONS_OFFICER
- INVESTMENT_OFFICER
- SHARIAH_BOARD_MEMBER
- BRANCH_MANAGER
- SYSTEM_ADMIN

Backend also has extensive permission code coverage and controller-level permission checks.

Main gap

Process ownership is not always explicit. In several modules, create/open/review/approve actions exist, but the exact business role ownership should be tightened.

Recommended role-process matrix

Customer / Account Holder

- View own accounts, financing, contracts, statements
- Create customer-facing requests only where business allows
- Request statements
- View deposit scheme enrollment and financing application status

Teller / Branch Staff

- Collect onboarding documents
- Initiate customer/account opening requests
- Cash deposit and withdrawal
- Cheque and transaction intake
- Start statement requests for customers
- Limited ATM or vault operational tasks only if approved by branch policy

Operations Officer

- KYC verification
- Account verification and activation workflow
- Transaction reversal
- Card operations
- Contract generation
- Notification/reports operations
- Closing support and control operations

Investment Officer (Financing)

- Financing application processing
- Document completeness check

- Risk/portfolio assessment
- Disbursement preparation
- Repayment and recovery follow-up

Shariah Board Member

- Shariah case review
- Contract compliance review
- Financing compliance approval
- Correction request and final sign-off

Branch Manager

- Branch approvals
- Vault opening and daily cash control
- High-value transaction approval
- Operational exception review
- EOD and monthly closing sign-off

System Admin

- User, role, permission, lookup, system configuration
- verification provider configuration
- audit monitoring
- integration/provider setup
- no business approval responsibility by default

5. Additional Roles Recommended For Real Operation

To make the process more realistic, these extra roles are recommended:

Compliance Officer

- audit review
- suspicious activity review
- regulatory report validation
- evidence and control follow-up

Recovery Officer

- overdue financing follow-up
- recovery promise tracking
- recovery report ownership

MIS / Reporting Officer

- scheduled report generation
- monthly pack preparation
- branch and management reporting validation

Internal Auditor

- read-only audit access
- report review
- process and control validation

Treasury / Finance Officer

- closing control
- consolidated balance and P&L review
- monthly financial pack validation

Priority Gap List

High Priority

1. WebSocket infrastructure
2. Real SMTP email activation and end-to-end test
3. Monthly closing process engine
4. Recovery report and overdue workflow
5. Role-process ownership refinement

Medium Priority

1. Profit/loss formal reporting
2. Growth reporting pack
3. Real-time notification center
4. Automated mail event expansion

Lower Priority

1. Additional executive dashboards
2. Optional mobile/push notification integration
3. Advanced scheduler-based report dispatch

Step-By-Step Execution Plan

Step 1: Verify Existing Foundations

- confirm OTP email works with real SMTP
- confirm SMS provider path
- confirm workflow history reflects real actions
- confirm permission checks match frontend menus
- confirm current financing and report modules return valid data

Step 2: Implement WebSocket

- backend config
- notification event publisher
- Angular realtime service
- notification widget and inbox
- role-aware event routing

Step 3: Harden Email Automation

- SMTP setup
- branded email templates

- event-triggered automated mail
- failure/retry log review

Step 4: Build Monthly Closing

- period master
- checklist
- branch closing status
- posting validation
- approval chain
- close/reopen control

Step 5: Build Formal Reporting Pack

- P&L
- financing tracking
- recovery report
- growth report
- KPI management pack

Step 6: Role And RBAC Refinement

- map each create/open/review/approve action to one owner role
- add missing roles
- update menu access and permissions
- verify controller and frontend route alignment

Step 7: Full UAT / Process Test

- customer journey
- teller journey
- operations journey
- financing journey
- shariah journey
- branch manager journey
- system admin journey
- compliance/recovery/MIS journey

Suggested Test Scenarios

OTP And Mail

- send login OTP by email
- resend OTP
- verify OTP
- forgot password OTP
- provider failure fallback

Workflow

- KYC review and approval
- account opening approval

- financing review to disbursement
- contract generation and sign flow

Reporting

- statement preview, print, PDF, Excel
- operational report preview/export
- financing portfolio report preview/export
- monthly closing report pack

RBAC

- wrong role denied
- correct role allowed
- hidden menu not directly accessible
- backend permission still blocks unauthorized direct API call

Final Recommendation

The project already has a strong base in:

- RBAC foundation
- OTP and verification flow
- workflow support
- reporting and export foundation
- financing and operational modules

The next best delivery sequence is:

1. Activate and validate real email OTP and automated mails
2. Add WebSocket for real-time notification and workflow events
3. Implement monthly closing and recovery reporting
4. Formalize P&L, KPI, growth, and financing recovery reports
5. Tighten role-process ownership and add missing operational roles

Expected Deliverables

After the above work, the project should have:

- real-time notification architecture
- live OTP email and automated mail workflow
- formal monthly closing process
- management-grade finance and recovery reports
- cleaner role-to-process ownership
- stronger enterprise-ready RBAC